



THREAT ADVISORY

**ATTACK
REPORT**

Exploitation of Follina leads to takeover of domain controller

Date of Publication

November 3, 2022

Admiralty Code

A1

TA Number

TA2022243

Summary

The recent incident is related to TA570, wherein the attackers exploited the Follina vulnerability (CVE-2022-30190) to compromise the Domain Controller and eventually gain access to confidential files.

⚙️ CVE Table

CVE	NAME	PATCH
CVE-2022-30190	Microsoft Windows Support Diagnostic Tool (MSDT) Remote Code Execution Vulnerability	

⚙️ Potential MITRE ATT&CK TTPs

<u>TA0002</u> Execution	<u>TA0005</u> Defense Evasion	<u>TA0007</u> Discovery	<u>TA0006</u> Credential Access
<u>TA0008</u> Lateral Movement	<u>TA0011</u> Command and Control	<u>T1059</u> Command and Scripting Interpreter	<u>T1059.001</u> PowerShell
<u>T1203</u> Exploitation for Client Execution	<u>T1218</u> System Binary Proxy Execution	<u>T1218.010</u> Regsvr32	<u>T1053</u> Scheduled Task/Job
<u>T1055</u> Process Injection	<u>T1562</u> Impair Defenses	<u>T1562.001</u> Disable or Modify Tools	<u>T1033</u> System Owner/User Discovery
<u>T1049</u> System Network Connections Discovery	<u>T1069</u> Permission Groups Discovery	<u>T1069.002</u> Domain Groups	<u>T1482</u> Domain Trust Discovery
<u>T1003</u> OS Credential Dumping	<u>T1003.001</u> LSASS Memory	<u>T1555</u> Credentials from Password Stores	<u>T1555.003</u> Credentials from Web Browsers
<u>T1555.004</u> Windows Credential Manager	<u>T1021</u> Remote Services	<u>T1021.001</u> Remote Desktop Protocol	<u>T1570</u> Lateral Tool Transfer
<u>T1071</u> Application Layer Protocol	<u>T1219</u> Remote Access Software	<u>T1105</u> Ingress Tool Transfer	

Technical Details

#1

To acquire initial access, a threat actor TA570 exploited the CVE-2022-30190 (Follina) vulnerability by embedding exploit code inside a malicious Word document and infecting the host with Qbot malware.

#2

The MSDT payload creates an instance of Scripted Diagnostics Native Host upon execution. As a result of scheduling tasks across multiple endpoints, Qbot can maintain its persistence.

✂ Indicator of Compromise (IOC)

TYPE	VALUE
SHA256	d20120cc046cef3c3f0292c6cbc406fcf2a714aa8e048c9188f1184e4bb16c93,63315df7981130853d75dc753e5776bdf371811bcfce351557c1e45afdd1ebfb,077ca8645a27c773d9c881aecf54bc409c2f8445ae8e3e90406434c09ace4bc2
SHA1	dab316b8973ecc9a1893061b649443f5358b0e64,03ef0e06d678a07f0413d95f0deb8968190e4f6b,3112a39aad950045d6422fb2abe98bed05931e6c
MD5	5abb2c12f066ce32a0e4866fb5bb347f,e7015438268464cedad98b1544d643ad,f76954b68cc390f8009f1a052283a740
Domain	incredibletadoba[.]com ibuonisani[.]it gruposolel[.]com foxmotorent[.]com egofit.co[.]uk edifica[.]ro dwm-me[.]com cursosfnn[.]com cemavimx[.]com atlasbar[.]net

TYPE	VALUE
IPV4:Port	144[.]202[.]3[.]39:443 67[.]209[.]195[.]198:443 176[.]67[.]56[.]94:443 72[.]252[.]157[.]93:995 90[.]120[.]65[.]153:2078 190[.]123[.]44[.]126:443 38[.]70[.]253[.]226:2222 182[.]191[.]92[.]203:995 37[.]186[.]54[.]254:995 140[.]82[.]63[.]183:443 41[.]86[.]42[.]158:995 89[.]101[.]97[.]139:443 201[.]145[.]165[.]25:443 173[.]21[.]10[.]71:2222 82[.]41[.]63[.]217:443 73[.]151[.]236[.]31:443 149[.]28[.]238[.]199:443 83[.]110[.]218[.]147:993 86[.]195[.]158[.]178:2222

Patch Links

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-30190>

References

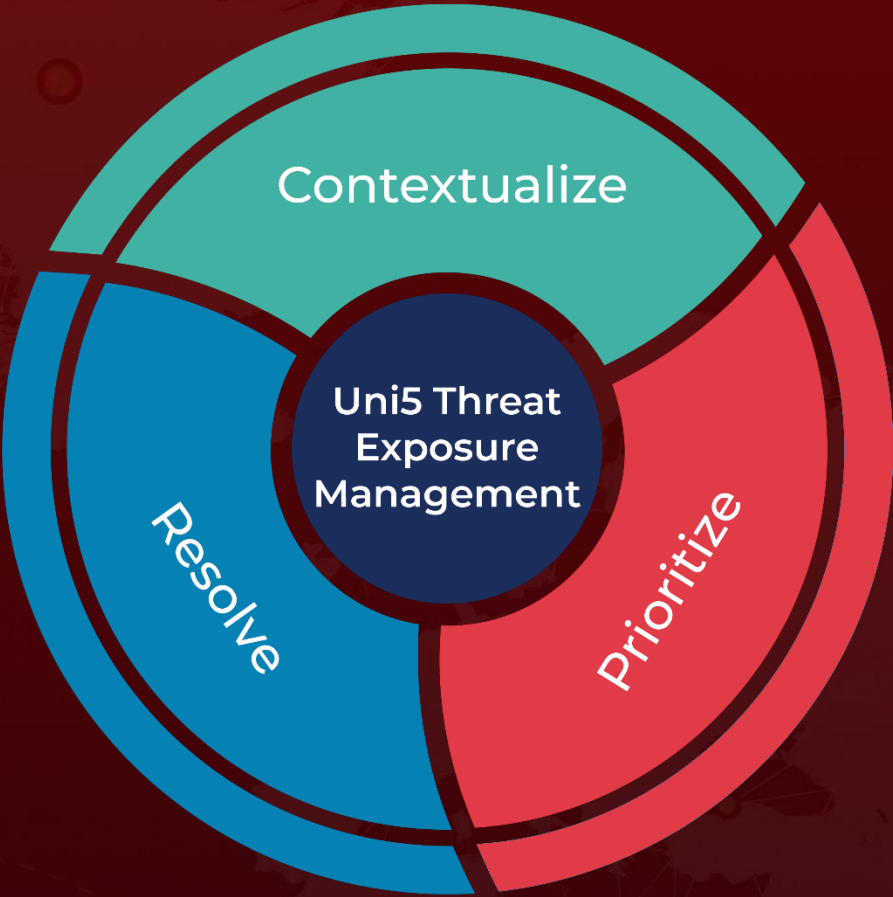
<https://thedfirreport.com/2022/10/31/follina-exploit-leads-to-domain-compromise/>

<https://cybersecuritynews.com/follina-exploit/>

What Next?

At HivePro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with Hive Pro Uni5: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON
November 3, 2022 • 5:55 AM

